

Домашнє завдання до теми 12

Оцінка рівня зрілості кібербезпеки організації

1. Опис компанії

Об'єктом оцінки є проєкт компанії умовно "Uni DevOps Labs" — команда, що розробляє та експлуатує веб-застосунок на базі Django, орієнтований на надання онлайн-сервісу невеликому колу клієнтів. Інфраструктура компанії будується за підходом Infrastructure as Code: мережеве середовище (VPC), реєстр контейнерів (ECR) та кластер Kubernetes (Amazon EKS) описані через Terraform-модулі, а розгортання застосунку в кластері здійснюється за допомогою Helm-чартів.

Сфера діяльності компанії — розробка та супровід внутрішніх/клієнтських вебзастосунків із використанням хмарної інфраструктури AWS. Команда перебуває на початковому етапі формалізації DevOps- та security-процесів: базова інфраструктура вже описана в коді, окремі елементи (наприклад, IAM-конфігурація для розгортання в EKS) допрацьовуються, а частина процесів (моніторинг, реагування на інциденти) поки не формалізована.

2. Обрана модель оцінки зрілості

Для оцінки обрано NIST Cybersecurity Framework (NIST CSF), оскільки він добре підходить для невеликих і середніх команд на ранній стадії формалізації безпеки, не потребує складної організаційної структури (на відміну від CMMI) та дозволяє оцінювати зрілість окремо за функціональними напрямками. Це важливо для компанії, де різні аспекти безпеки (доступ, моніторинг, реагування) перебувають на різних стадіях розвитку.

NIST CSF виділяє п'ять основних функцій:

- Identify — ідентифікація активів, ризиків та вимог до безпеки;
- Protect — заходи захисту (контроль доступу, шифрування, навчання персоналу);
- Detect — виявлення аномалій та інцидентів безпеки;
- Respond — реагування на виявлені інциденти;
- Recover — відновлення роботи систем після інциденту.

Для кожної функції зрілість оцінювалася за чотирма рівнями: 1 — Partial (частковий, реактивний), 2 — Risk Informed (є усвідомлення ризиків, але процеси не формалізовані), 3 — Repeatable (процеси задокументовані й повторювані), 4 — Adaptive (процеси постійно вдосконалюються на основі метрик).

3. Аналіз поточного рівня безпеки

Аналіз базується на документації та артефактах, створених протягом курсу: репозиторій компанії на GitHub, що містить Terraform-модулі (S3 backend, VPC, ECR) та Docker/Helm-конфігурацію Django-застосунку, а також матеріали поточного завдання з розгортання застосунку на AWS EKS.

Функція NIST CSF	Поточний стан	Рівень зрілості (1-4)	Ключовий доказ
Identify (Ідентифікація)	Активи описані у Terraform-модулях (VPC, ECR, EKS), але немає єдиного реєстру активів і формальної оцінки ризиків	Рівень 2 — Risk Informed	lesson-5: модулі S3 backend, VPC, ECR
Protect (Захист)	IAM-ролі та політики створюються через Terraform, але принцип найменших привілеїв не	Рівень 2 — Risk Informed	IAM-конфігурація lesson-7 (Phase 2, в процесі)

	завжди формалізований; секрети частково в Helm values		
Detect (Виявлення)	Моніторинг обмежується базовими логами Kubernetes/CloudWatch за замовчуванням; немає централізованого SIEM чи алертингу	Рівень 1 — Partial	Відсутність окремого модуля логування/моніторингу в репозиторії
Respond (Реагування)	Формалізованого плану реагування на інциденти немає; дії у разі збою вирішуються ситуативно	Рівень 1 — Partial	Відсутність runbook/IR-документації в проєкті
Recover (Відновлення)	Інфраструктура як код (Terraform) дозволяє відносно швидко перерозгорнути середовище, але немає задокументованої процедури DR	Рівень 2 — Risk Informed	Модульна структура Terraform дозволяє повторне розгортання

Ключові спостереження:

- Формалізовані політики кібербезпеки практично відсутні: є технічна реалізація контролю доступу через IAM, але немає документа з політикою безпеки, який би описував правила доступу, паролів, ротації ключів тощо.
- Контроль доступу реалізований на рівні IAM-ролей AWS, проте конфігурація ще перебуває в процесі узгодження (перевірка коректності IAM для розгортання в EKS), що свідчить про відсутність усталеного процесу перевірки прав перед розгортанням.
- Моніторинг та виявлення загроз обмежені стандартними засобами AWS/Kubernetes без додаткової кореляції подій чи централізованого збору логів.
- Формального плану реагування на інциденти (Incident Response Plan) не виявлено; дії у разі збою чи компрометації middleware не описані.
- Метрики безпеки (кількість вразливостей, час виявлення, час реагування) не збираються і не аналізуються.

4. Висновки щодо рівня зрілості організації

Загальний рівень зрілості кібербезпеки компанії відповідає рівню 2 (Risk Informed) за шкалою NIST CSF із помітним відставанням функцій Detect та Respond, які фактично перебувають на рівні 1 (Partial). Це типова ситуація для команди, яка вже впровадила Infrastructure as Code та базовий контроль доступу, але ще не побудувала процеси виявлення й реагування на інциденти. Сильна сторона — використання Terraform, що дає відтворюваність інфраструктури та полегшує майбутнє впровадження засобів безпеки "як коду". Найслабша ланка — відсутність моніторингу подій безпеки та плану реагування на інциденти, що створює ризик пізнього виявлення компрометації та повільного відновлення після інциденту.

5. Рекомендації щодо вдосконалення кібербезпеки

5.1 Впровадження SIEM-системи для централізованого моніторингу

Налаштувати збір логів з EKS (control plane logging), додатку Django та AWS CloudTrail у централізовану систему (наприклад, Amazon Security Lake, Wazuh або ELK/OpenSearch стек) з базовими правилами кореляції та алертингом у Slack/email. Це підніме функцію Detect з рівня 1 до рівня 2-3.

5.2 Автоматизація управління вразливостями

Інтегрувати сканування образів контейнерів (наприклад, Trivy або Amazon ECR image scanning) у CI/CD пайплайн, а також регулярне сканування Terraform-конфігурацій на предмет помилок безпеки (tfsec, Checkov). Це дозволить виявляти вразливості до розгортання, а не постфактум.

5.3 Формалізація процесу реагування на інциденти

Розробити короткий Incident Response Runbook: хто відповідальний, які кроки при підозрі на компрометацію (ізоляція поду/ноди, ротація ключів IAM, відкат через Terraform/Helm), канали комунікації. Навіть базовий документ на 1-2 сторінки суттєво підвищить готовність команди.

5.4 Регулярні Red Team / Blue Team вправи

Проводити періодичні навчальні вправи (наприклад, раз на квартал) — імітацію інциденту (скомпрометований под, витік облікових даних) із відпрацюванням дій команди за розробленим runbook. Це переведе функції Respond і Recover з рівня 1-2 до рівня 3 (Repeatable).

5.5 Формалізація політик доступу

Задокументувати принцип найменших привілеїв для IAM-ролей, використовуваних Terraform та Kubernetes service account'ами, і перевести секрети застосунку з Helm values у керований сервіс секретів (AWS Secrets Manager або HashiCorp Vault) із автоматичною ротацією.